PROCUREIQ SOC2 TYPE II & FINTECH SECURITY ARCHITECTURE GUIDE

==========

Document ID: SEC-SOC2-2026
Last Audited: 2026-11-01

Key Security Controls Implemented in ProcureIQ Platform:

1. Durable PostgreSQL Checkpointing: LangGraph states and HITL interrupts persist in agent_checkpoints / agent_checkpoint_blobs / agent_checkpoint_writes across server restarts.
2. Multi-Tenant Isolation: kb_chunks, sessions, and audit_log strictly partition by tenant_id so queries and KB RAG never leak documents across customer workspaces.
3. Role-Based Access Control (RBAC): HS256 JWT tokens and X-API-Key identities enforce viewer, operator, finance_vp ($25,000+ PO gate), and admin privileges.
4. Transport Security & Rate Limiting: TLS certificate verification enabled by default (GEMINI_VERIFY_SSL=true) and sliding-window IP rate limiting (HTTP 429).